

SIMATS ENGINEERING ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1408

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01

Total Marks:100

Annexure A
VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

*I P.Ranjithkumar (192411119) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: Prky

Annexure A

1.TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

Aim :To perform a vulnerability assessment of a controlled laboratory system and identify security weaknesses related to network exposure, authentication, encryption, outdated services, and access control that are relevant to the TJX Companies wireless breach.

Incident Background

TJX Companies experienced a major payment-card data breach between 2005 and 2007. The U.S. Federal Trade Commission reported unauthorized network access, clear-text personal information, interception of payment-card authorization requests, and transmission of stolen information to remote systems.

The incident demonstrated the importance of secure wireless access, strong authentication, network segmentation, encryption, monitoring, and protection of payment information.

Tools Used

1. Kali Linux
2. Nmap
3. cURL
4. Metasploitable 2
5. VirtualBox

Target: 192.168.56.102

Practical Procedure and Evidence :

Step 1 : Service and Version Detection

Command: `nmap -sV 192.168.56.102`

- The scan identified numerous services including FTP, SSH, Telnet, HTTP, HTTPS, SMB.

Finding: The system exposes a large number of network services, increasing the attack surface.

```
kali@kali:~$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:29 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0019s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 6ubuntu1 (protocol 2.0)
23/tcp    open  telnet       linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache/2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
443/tcp   open  https        Apache/2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        netkit-rshd
1099/tcp  open  java-remote  GNU Classpath gmrregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu2
5432/tcp  open  postgresql   PostgreSQL 8m 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6880/tcp  open  x11          (access denied)
6881/tcp  open  irc          UnrealIRCd
8089/tcp  open  ajp13        Apache/2.2.8 (Ubuntu) mod_jk (Apache/2.2.8)
8180/tcp  open  http         Apache/2.2.8 (Ubuntu) mod_ssl (Apache/2.2.8)
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.16 seconds

kali@kali:~$ nmap -p 21,22,23,53,80,111,139,443,445,512,513,514,1524,2049,2121,3306,5432,5900,6880,8089,8180 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:30 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0070s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  netbios-ssn
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
8089/tcp  open  ajp13
8180/tcp  open  http
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Step 2 : FTP Anonymous Authentication

Command : `nmap -p 21 --script ftp-anon 192.168.56.102`

Finding : Anonymous access represents weak authentication and access control.

```
kali@kali:~$ nmap -p 21 --script ftp-anon 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:30 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0070s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds

kali@kali:~$ nmap -p 139,445 --script smb-enum-shares 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:30 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0019s latency).
PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
| smb-enum-shares:
|_ account_used: c:\admins
|_ \192.168.56.102\ADMIN$:
|_ Type: STYPE_IPC
|_ Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|_ Users: 1
|_ Max Users: cunlimited
|_ Path: C:\tmp
|_ Anonymous access: <none>
|_ \192.168.56.102\IPC$:
|_ Type: STYPE_IPC
|_ Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|_ Users: 1
|_ Max Users: cunlimited
|_ Path: C:\tmp
|_ Anonymous access: READ/WRITE
|_ \192.168.56.102\opt:
|_ Type: STYPE_DISKTREE
|_ Comment:
|_ Users: 1
|_ Max Users: cunlimited
|_ Path: C:\tmp
|_ Anonymous access: <none>
|_ \192.168.56.102\print$:
|_ Type: STYPE_DISKTREE
```

Step 3 : SMB Share Enumeration

Command : nmap -p 139,445 --script smb-enum-shares 192.168.56.102

- The assessment identified SMB shares including a share with READ/WRITE access.

Finding: Excessive or anonymous access to network shares can expose sensitive information.

Step 4: HTTP Server Assessment

Command : curl -I http://192.168.56.102

- The response identified an old Apache/PHP environment.

Finding: Legacy server software increases the possibility of known vulnerabilities.

```

kali@kali: ~
Session Actions Edit View Help
| \\192.168.56.102\print$:
| Type: STYPE_DISKTREE
| Comment: Printer Drivers
| Users: 1
| Max Users: unlimited
| Path: C:\Var\lib\samba\printers
| Anonymous access: <none>
| \\192.168.56.102\tps:
| Type: STYPE_DISKTREE
| Comment: dh.muesl
| Users: 1
| Max Users: unlimited
| Path: C:\tmp
| Anonymous access: READ/WRITE

nmap done: 1 IP address (1 host up) scanned in 1.41 seconds

kali@kali:~$ curl -i http://192.168.56.102
HTTP/1.1 200 OK
Date: Sat, 15 Aug 2020 08:31:02 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
X-Powered-By: PHP/5.2.4-2ubuntu3.10
Content-Type: text/html

kali@kali:~$ nmap -p 443 --script ssl-cert 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-15 04:31 EDT
Nmap scan report for 192.168.56.102
Host is up (0.020s latency).

PORT: STATE SERVICE
443/tcp open  https
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.43 seconds

kali@kali:~$ nmap -p 443 --script ssl-enum-ciphers 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-15 04:33 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0017s latency).

PORT: STATE SERVICE
443/tcp open  https
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 20.96 seconds

kali@kali:~$

```

Step 5 : HTTPS Assessment

Command : nmap -p 443 --script ssl-cert 192.168.56.102

Finding: The HTTPS service was detected.

Vulnerabilities Identified

- Excessive network service exposure.
- Anonymous FTP authentication.
- Weak SMB access control.
- Legacy Apache/PHP versions.
- Inadequate protection of sensitive network resources.
- Insufficient segmentation between services and sensitive systems.
- Potential exposure of sensitive information if insecure protocols are used.

Risk and Impact

Overall Risk: HIGH

- An attacker obtaining unauthorized network access could potentially move from an exposed service toward internal systems. In a retail environment, inadequate segmentation could allow an initial wireless compromise to reach payment-processing infrastructure.

Recommendations

- Replace obsolete wireless encryption such as WEP with WPA2 -Enterprise or WPA3-Enterprise.
- Use 802.1X/RADIUS authentication.
- Separate wireless, POS and corporate networks using VLANs and firewalls.
- Disable anonymous FTP and unnecessary services.
- Apply regular security patches.
- Implement wireless intrusion detection.
- Monitor rogue access points.
- Encrypt payment data both in transit and at rest.
- Apply appropriate PCI DSS controls to payment-card environments.
- Implement centralized logging and continuous monitoring.

2.Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

Aim : To assess how a weakly protected wireless network can provide an entry point into internal systems and evaluate authentication, network isolation, firewall controls and service exposure.

Incident Background : In 2003, attackers compromised a wireless network at a Lowe's store in Southfield, Michigan. According to the U.S. Department of Justice, the attackers used the wireless connection to gain unauthorized access to Lowe's central computer systems and attempted to install software intended to capture customer credit-card information.

The case demonstrates why wireless networks must be isolated from sensitive corporate and POS systems.

Tools Used

6. Kali Linux
7. Nmap
8. Metasploitable 2
9. Wireshark
10. VirtualBox

Target: 192.168.56.102

Practical Procedure

Step 1 : Host Discovery

Command: `nmap -sn 192.168.56.0/24`

The laboratory network identified the Metasploitable system at : 192.168.56.102

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history

[kali@kali]~$ ping -c 4 192.168.56.102
PING 192.168.56.102: 192.168.56.102 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=4.51 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=2.02 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.68 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=2.33 ms
--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 309ms
rtt min/avg/max/mdev = 1.661/2.625/4.507/1.110 ms

[kali@kali]~$ nmap 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 03:51 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0075s latency).
Not shown: 976 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3386/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6080/tcp  open  x11
6667/tcp  open  irc
8080/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds

[kali@kali]~$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 03:52 EDT
Status: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 45.82% done; ETC: 03:52 (0:00:07 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.0075s latency).
Not shown: 976 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 5ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
443/tcp   open  https        Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
445/tcp   open  smb          Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  java-remote  GNU Classpath gmiiregistry
1524/tcp  open  ingresshell  Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3386/tcp  open  mysql        MySQL 5.0.51a-ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6080/tcp  open  x11          (access denied)
6667/tcp  open  irc           UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.lan, OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.26 seconds
```

Step 2 : Service Enumeration

Command: `nmap -sV 192.168.56.102`

- Multiple services were identified, including FTP, Telnet, HTTP, SMB, MySQL and other services.

Finding: Multiple exposed services increase the attack surface.

```
Session Actions Edit View Help

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds

[kali@kali]~$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 03:52 EDT
Status: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 45.82% done; ETC: 03:52 (0:00:07 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.0075s latency).
Not shown: 976 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 5ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
443/tcp   open  https        Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
445/tcp   open  smb          Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  java-remote  GNU Classpath gmiiregistry
1524/tcp  open  ingresshell  Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3386/tcp  open  mysql        MySQL 5.0.51a-ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6080/tcp  open  x11          (access denied)
6667/tcp  open  irc           UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.lan, OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.26 seconds

[kali@kali]~$ curl -i http://192.168.56.102
HTTP/1.1 200 OK
Date: Sat, 15 Aug 2026 07:53:27 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
```

Step 3: FTP Authentication Assessment

Command: `nmap -p 21 --script ftp-anon 192.168.56.102`

Finding: Weak authentication can allow unauthorized users to access network resources.

```
kali@kali:~$ nmap -p 21 --script ftp-anon 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 03:53 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0075s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.07 seconds

kali@kali:~$ nmap -p 139,445 --script smb-enum-shares 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 03:53 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0022s latency).

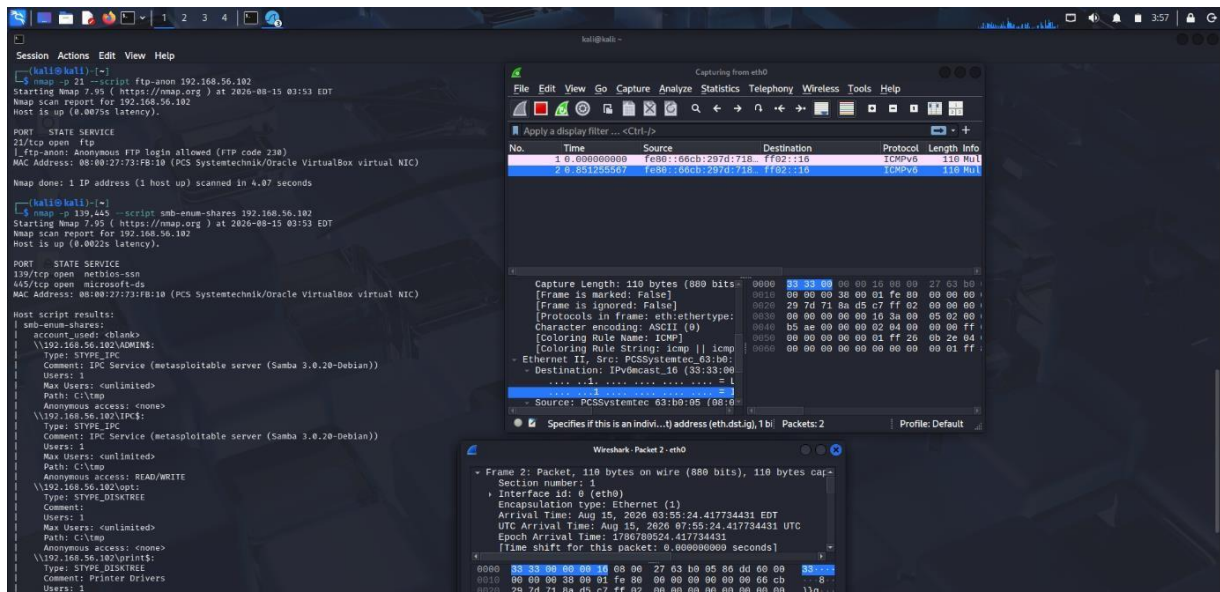
PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|smb-enum-shares:
|_account_used: <blank>
|_\\192.168.56.102\ADMIN$:
|_  Type: STYPE_IPC
|_  Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|_  Users: 1
|_  Max Users: <unlimited>
|_  Path: C:\tmp
|_  Anonymous access: <none>
|_\\192.168.56.102\IPC$:
|_  Type: STYPE_IPC
|_  Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|_  Users: 1
|_  Max Users: <unlimited>
|_  Path: C:\tmp
|_  Anonymous access: READ/WRITE
|_\\192.168.56.102\opt:
|_  Type: STYPE_DISKTREE
|_  Comment:
|_  Users: 1
|_  Max Users: <unlimited>
|_  Path: C:\tmp
|_  Anonymous access: <none>
|_\\192.168.56.102\printers:
|_  Type: STYPE_DISKTREE
|_  Comment: Printer Drivers
|_  Users: 1
```

Step 4 : SMB Assessment

- Command: `nmap -p 139,445 --script smb-enum-shares 192.168.56.102`
- The scan identified SMB shares and anonymous access.

Finding: Improperly isolated network shares can facilitate unauthorized access.



Step 5 : Traffic Observation

Wireshark was used to observe network traffic in the controlled laboratory environment.

Vulnerabilities :

- Weak authentication
- Excessive service exposure
- Poor network isolation
- Inadequate access control
- Potentially insecure legacy protocols
- Insufficient monitoring

Risk

Overall Risk: HIGH

If a wireless network is directly connected to corporate or POS infrastructure, compromise of the wireless segment could provide an attacker with a path toward sensitive systems.

Recommendations

- Use WPA2/WPA3-Enterprise.
- Implement 802.1X authentication.
- Place guest/wireless devices in separate VLANs.
- Isolate POS systems from general wireless networks.
- Use internal firewalls between network segments.
- Disable unnecessary services.
- Implement centralized authentication.
- Deploy IDS/IPS.
- Monitor wireless access points.
- Apply least-privilege access.

Result

The assessment demonstrated how weak authentication, exposed services and insufficient network isolation can increase the risk of lateral movement from a wireless environment into sensitive systems.

2. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

Aim : To examine the security risks associated with public Wi-Fi and unencrypted HTTP sessions, particularly the possibility of session-cookie exposure and session hijacking.

Incident Background : Firesheep, released in 2010, demonstrated how session cookies transmitted without adequate encryption could be captured on the same network and reused to impersonate an authenticated user. The demonstration highlighted the weakness of protecting only the login page while leaving subsequent session traffic unencrypted.

Tools Used

- Wireshark
- Windows laptop
- Network traffic capture
- Browser

Practical Procedure

Step 1 : Capture Network Traffic

- Wireshark was opened and network traffic was captured.
- The capture was filtered using : http

Http Packets :

1. GET / HTTP/1.1
2. HTTP/1.1 200 OK

```
Command Prompt
Microsoft Windows [Version 10.0.26200.9168]
(c) Microsoft Corporation. All rights reserved.

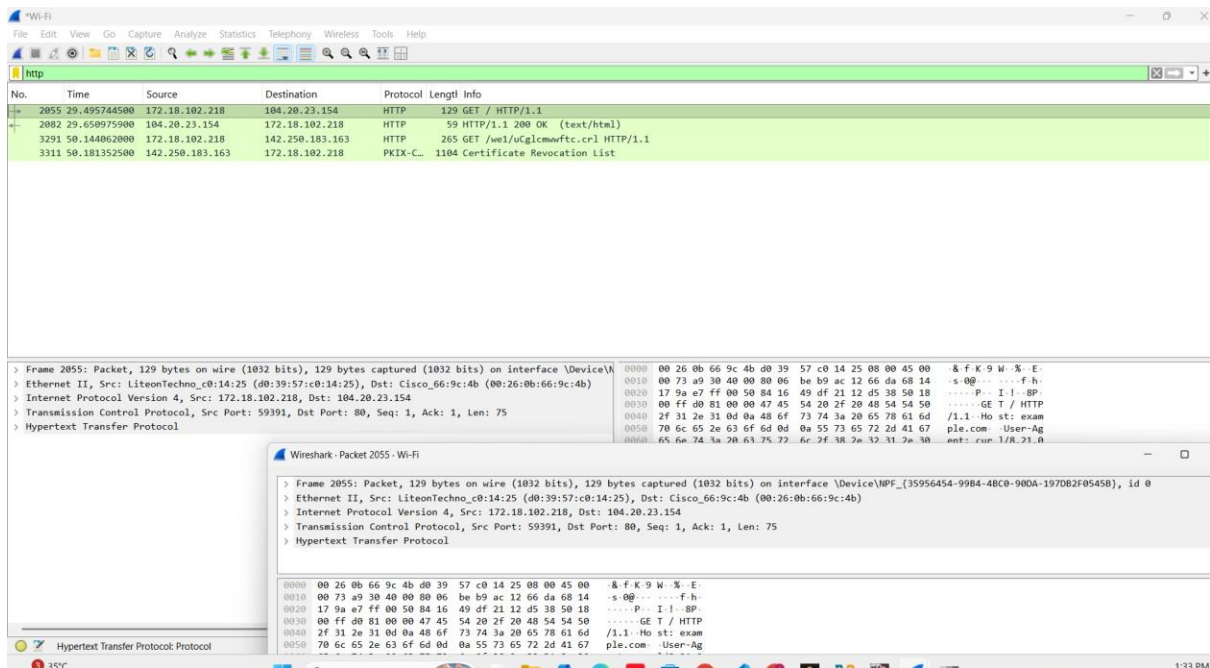
C:\Users\jahnavi kodavati>curl http://example.com
<!doctype html><html lang="en"><head><title>Example Domain</title><link rel="icon" href="data:,"><meta name="viewport" c
ontent="width=device-width, initial-scale=1"><style>body{background:#eee;width:60vw;margin:15vh auto;font-family:system-
ui,sans-serif}h1{font-size:1.5em}div{opacity:0.8}a:link,a:visited{color:#348}</style></head><body><div><h1>Example Domai
n</h1><p>This domain is for use in documentation examples without needing permission. Avoid use in operations.</p><p><a
href="https://iana.org/domains/example">Learn more</a></p></div></body></html>

C:\Users\jahnavi kodavati>curl https://example.com
<!doctype html><html lang="en"><head><title>Example Domain</title><link rel="icon" href="data:,"><meta name="viewport" c
ontent="width=device-width, initial-scale=1"><style>body{background:#eee;width:60vw;margin:15vh auto;font-family:system-
ui,sans-serif}h1{font-size:1.5em}div{opacity:0.8}a:link,a:visited{color:#348}</style></head><body><div><h1>Example Domai
n</h1><p>This domain is for use in documentation examples without needing permission. Avoid use in operations.</p><p><a
href="https://iana.org/domains/example">Learn more</a></p></div></body></html>

C:\Users\jahnavi kodavati>
```

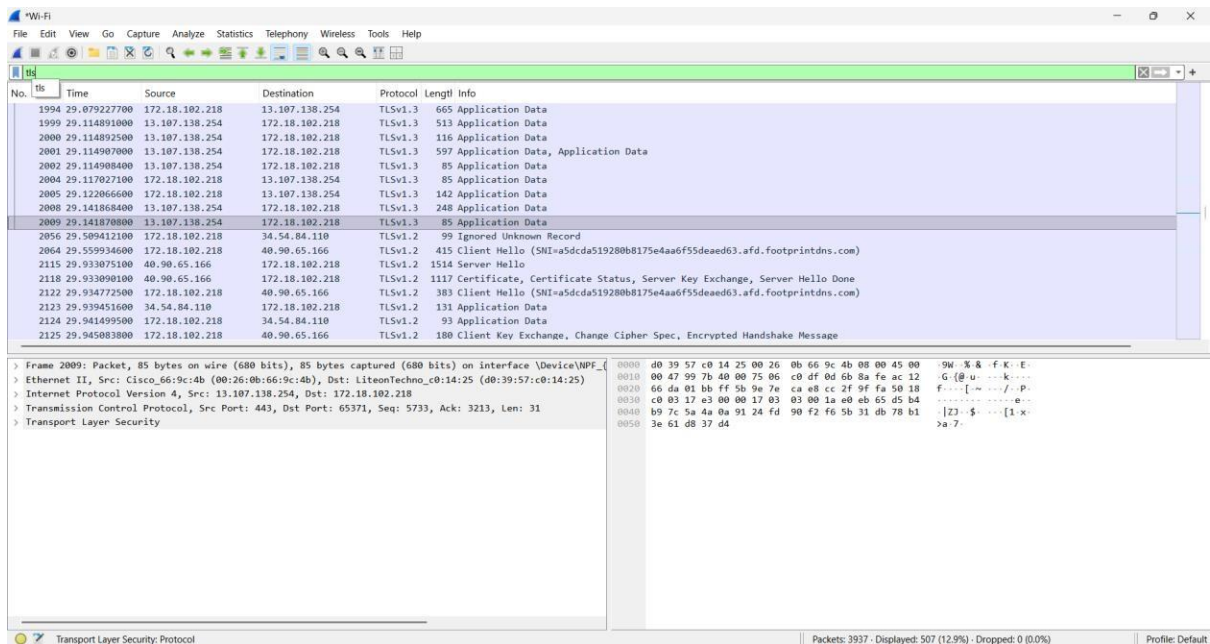
Step 2 : Examine an HTTP Packet

- An HTTP packet was selected to examine the protocol details.
- The packet demonstrates that HTTP traffic is not protected by TLS.



Step 3 : Compare with TLS Traffic

- Wireshark was also filtered using : tls
- The capture showed TLS 1.2/TLS 1.3 traffic.



Vulnerability Analysis

The main weakness demonstrated by the Firesheep scenario is:

- Unencrypted session traffic → exposed session cookie → possible session impersonation
- The actual Firesheep demonstration did not require stealing the user's password if the session identifier itself was transmitted insecurely.

Risk

Overall Risk: HIGH on vulnerable public networks

Possible consequences include:

- Account impersonation
- Privacy loss
- Unauthorized actions
- Exposure of session information
- Theft of sensitive web data

Result

Wireshark successfully demonstrated the difference between HTTP and TLS traffic in the controlled environment. The assessment confirms why full-session HTTPS and secure session-cookie handling are essential on public networks.

3. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

Aim : To assess security weaknesses related to hotel Wi-Fi, DNS, web services, secure communications, outdated software and malicious software-update risks.

Incident Background

DarkHotel was a targeted cyber-espionage campaign involving hotel networks and high-value business travelers. Researchers reported that selected hotel guests were presented with apparently legitimate software-update prompts that actually delivered malicious software.

The campaign demonstrated the importance of securing hotel Wi-Fi infrastructure, captive portals, update mechanisms, certificates and endpoint security.

Tools Used

- Nmap
- Nikto
- cURL
- Dig
- Metasploitable 2

Target : 192.168.56.102

Practical Procedure

Step 1 : DNS Service Assessment

Command : nmap -p 53 -sV 192.168.56.102

The scan identified : 53/tcp open domain ISC BIND 9.4.2

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history

[kali@kali]~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=4.09 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=4.01 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=3.79 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=1.69 ms
--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 308ms
rtt min/avg/max/mdev = 1.691/3.617/4.988/1200 ms

[kali@kali]~$ nmap -p 53 -v 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:39 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0017s latency).

PORT      STATE SERVICE
53/tcp    open  domain
53/udp    open  domain
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.76 seconds

[kali@kali]~$ dig @192.168.56.102 metasploitable.localdomain
; <<> DIG 9.20.15-2-Debian <<> @192.168.56.102 metasploitable.localdomain
; (1 server found)
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: SERVFAIL, id: 64892
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 4096
;; QUESTION SECTION:
;metasploitable.localdomain.  IN      A

;; Query time: 264 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Sat Aug 15 04:41:01 EDT 2026
;; MSG SIZE  rcvd: 53

[kali@kali]~$ dig @192.168.56.102 google.com
; <<> DIG 9.20.15-2-Debian <<> @192.168.56.102 google.com
; (1 server found)
```

Step 2 : DNS Query

Command : dig @192.168.56.102 metasploitable.localdomain

- A DNS query was sent to the laboratory DNS server.

Step 3 : HTTP/HTTPS Service Detection

Command : nmap -p 80,443 -sV 192.168.56.102

- The system exposed both HTTP and HTTPS services.

```
Session Actions Edit View Help
; (1 server found)
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: SERVFAIL, id: 30869
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 4096
;; QUESTION SECTION:
;google.com.  IN      A

;; Query time: 164 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Sat Aug 15 04:41:21 EDT 2026
;; MSG SIZE  rcvd: 39

[kali@kali]~$ nmap -p 80,443 -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:41 EDT
Nmap scan report for 192.168.56.102
Host is up (0.015s latency).

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.32 seconds

[kali@kali]~$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP:      192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port:    80
+ Start Time:    2026-08-15 04:42:43 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'cca' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15\_http://exchange.vforce.ibmcloud.com/vulnerabilities/8275
+ mod_ssl/2.2.8 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ OpenSSL/0.9.8g appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2022.
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54); Apache 2.2.34 is the EOL for the 2.x branch.
+ mod_ssl/2.2.8 OpenSSL/0.9.8g - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
```

Step 4 : Web Vulnerability Assessment

Command : nikto -h http://192.168.56.102

The scan identified:

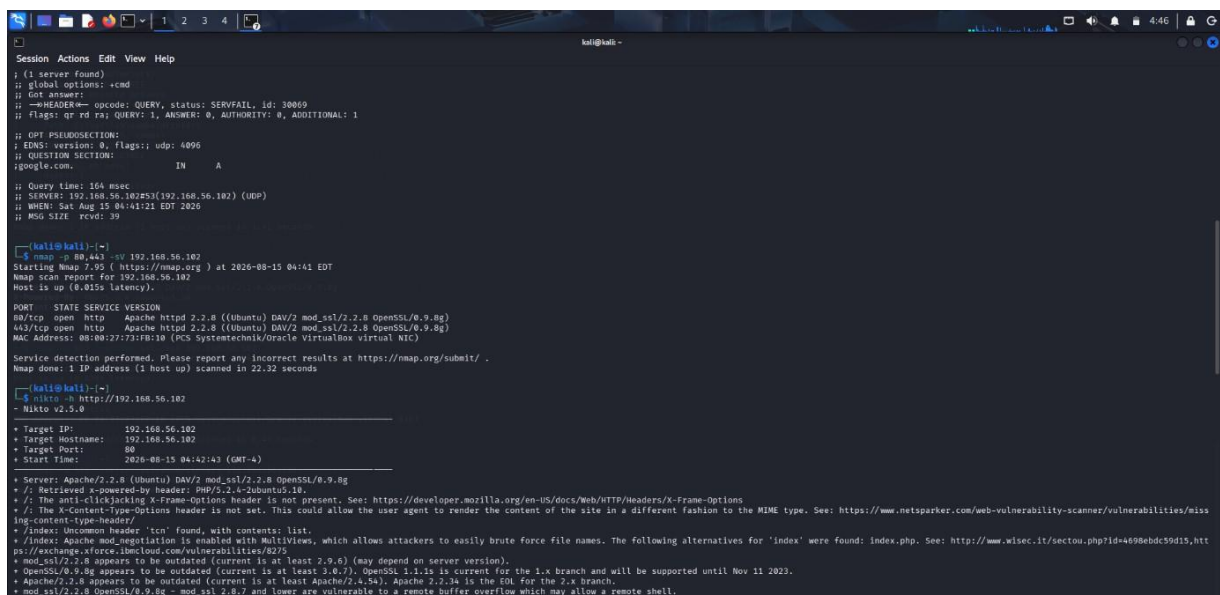
- Apache 2.2.8
- PHP 5.2.4
- Missing security headers
- Outdated Apache
- Outdated OpenSSL
- mod_negotiation enabled

Step 5 : HTTP Headers

Command : curl -I http://192.168.56.102

The response showed:

- Server: Apache/2.2.8
- X-Powered-By: PHP/5.2.4



```
Session Actions Edit View Help
; (1 server found)
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: SERVFAIL, id: 30069
;; Flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 4096
; QUESTION SECTION:
;google.com.                IN      A

;; Query time: 164 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Sat Aug 15 04:41:21 EDT 2026
;; MSG SIZE rcvd: 39

--(kali@kali)-[~]
$ nmap -p 80,443 -v 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 04:41 EDT
Nmap scan report for 192.168.56.102
Host is up (0.815s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
443/tcp   open  https     Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
MAC Address: 08:00:27:7F:F8:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.32 seconds

--(kali@kali)-[~]
$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-08-15 04:42:43 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: List.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4598ebdc59d15,http://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ mod_ssl/2.2.8 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ OpenSSL/0.9.8g appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ mod_ssl/2.2.8 OpenSSL/0.9.8g - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
```

Vulnerabilities Identified :

1. Outdated web server
2. Outdated PHP
3. Outdated OpenSSL

4. Missing HTTP security headers
5. DNS service exposure
6. Potentially weak web-server configuration
7. Risk of untrusted update delivery if the portal/server is compromised
8. Insufficient protection of third-party-managed infrastructure

Risk

Overall Risk: HIGH

- If a hotel captive portal or web server were compromised, attackers could potentially manipulate content presented to guests. In the DarkHotel case, attackers abused trusted hotel-network infrastructure to target selected guests with malicious software prompts.

Recommendations

- Use WPA2/WPA3-Enterprise.
- Implement secure guest authentication.
- Isolate guest networks using VLANs.
- Protect captive portals.
- Secure DNS infrastructure.
- Use HTTPS throughout the portal.
- Verify software-update digital signatures.
- Never distribute software updates directly from an untrusted captive portal.
- Patch web servers and operating systems.
- Implement endpoint anti-malware/EDR.
- Monitor privileged hotel-network systems.
- Audit third-party network providers.
- Maintain centralized logs.

Result

The laboratory assessment identified DNS exposure, outdated web components, missing security headers and insecure server configurations relevant to the security concerns demonstrated by the DarkHotel scenario.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

Aim : To assess the security risks associated with compromised administrator accounts, inadequate privileged-access management, captive-portal security, logging and third-party Wi-Fi administration.

Incident Background

On September 25, 2024, Wi-Fi services at 19 major UK railway stations were affected by an incident in which the public Wi-Fi landing page displayed unauthorized offensive content. Reports stated that the landing page had been changed using a legitimate administrator account. Network Rail and its Wi-Fi provider investigated the incident, and the affected Wi-Fi services were temporarily suspended.

The incident demonstrates that even when an attacker uses a legitimate account rather than directly exploiting the Wi-Fi protocol, inadequate privileged-access controls can compromise a public-facing service.

Tools Used

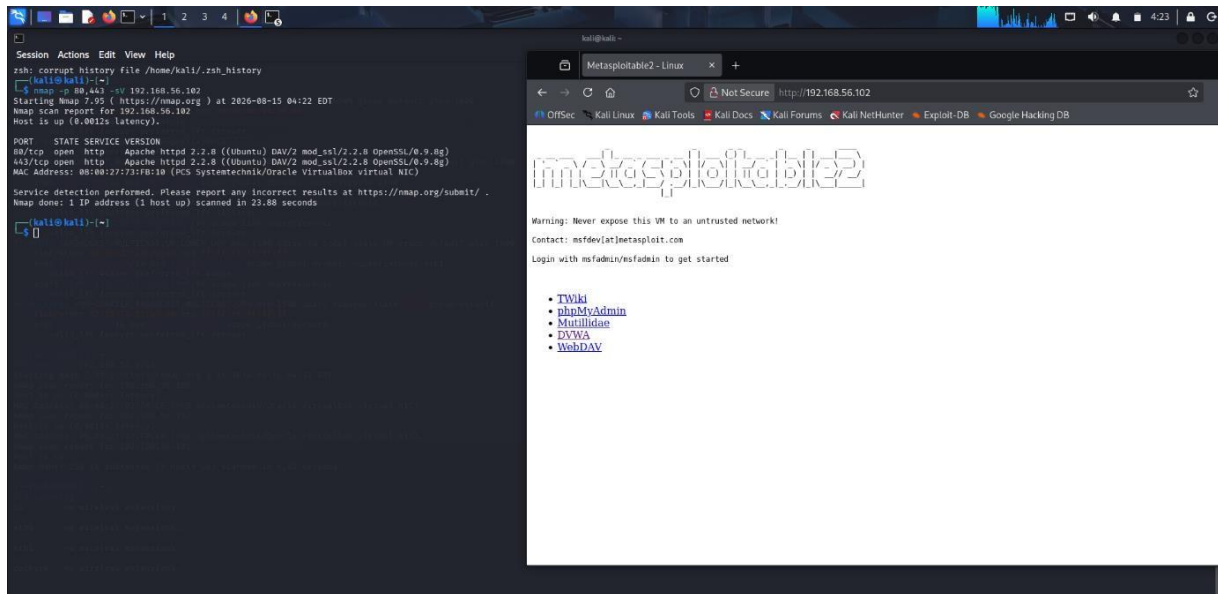
- Kali Linux
- OWASP ZAP
- Nmap
- cURL
- Metasploitable 2
- VirtualBox

Target : 192.168.56.102

Practical Procedure

Step 1: Identify the Web Service

Command : `nmap -p 80,443 -sV 192.168.56.102`



Step 2 : Access the Web Application

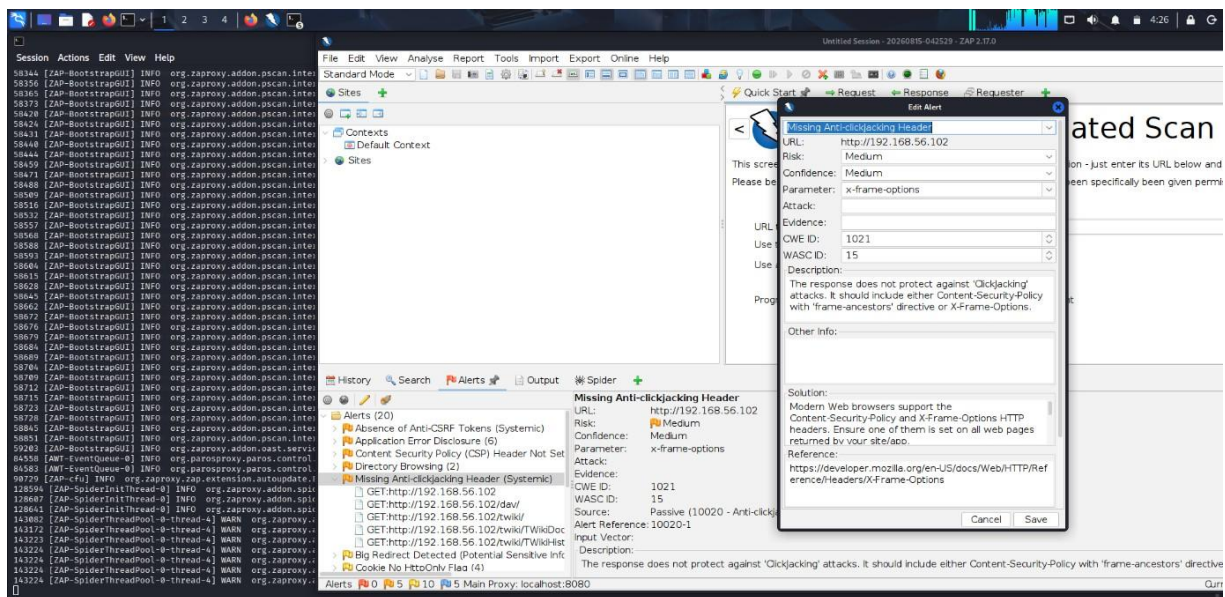
The Metasploitable web server was opened : `http://192.168.56.102`

Step 3 : OWASP ZAP Automated Scan

- OWASP ZAP was used against : `http://192.168.56.102`
- The scan identified multiple web-security alerts.

Alerts :

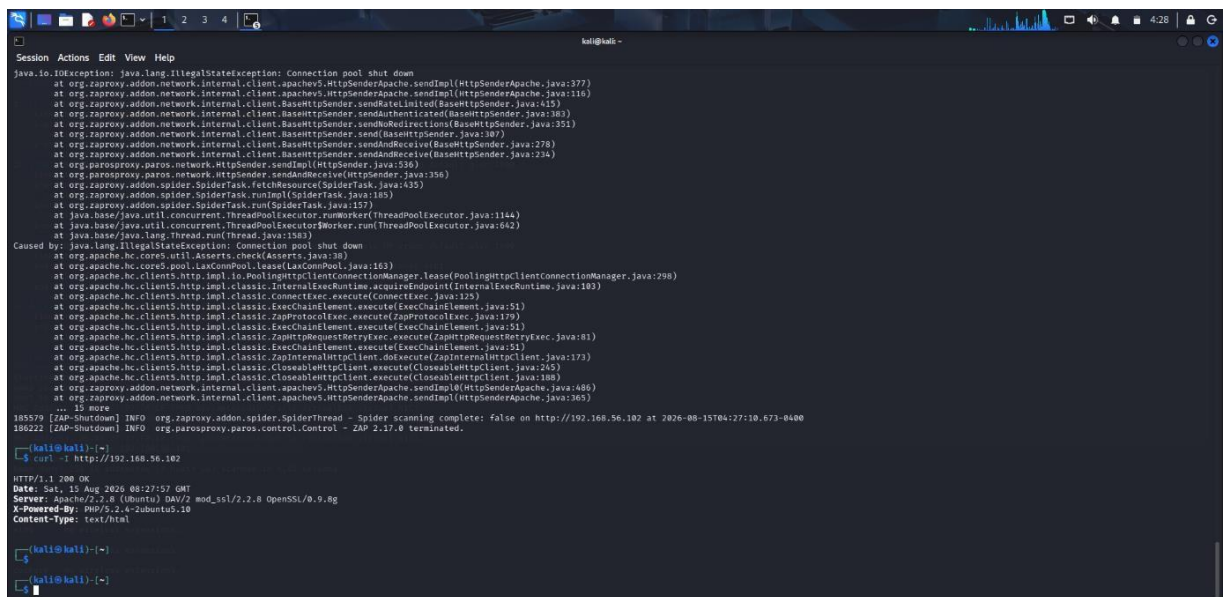
- Missing Anti-clickjacking Header
- Content Security Policy not set
- Application error disclosure
- Directory browsing
- Cookie security issues



Step 4 : Verify HTTP Headers

Command : `curl -I http://192.168.56.102`

The response identified the web server and its headers.



Vulnerabilities Identified

- Missing anti-clickjacking protection
- Missing Content Security Policy
- Directory browsing/exposure
- Weak cookie security configuration

- Legacy web-server components
- Insufficient web-security headers
- Risk associated with privileged administrator accounts
- Potential third-party administration risks

Risk

Overall Risk: HIGH

- A compromised legitimate administrator account can be particularly dangerous because activity may appear legitimate unless strong authentication, logging and behavioral monitoring are implemented.

Recommendations

- Implement MFA for all administrator accounts.
- Use privileged-access management.
- Apply least-privilege permissions.
- Separate administrator accounts from normal user accounts.
- Monitor administrator login locations and times.
- Maintain immutable audit logs.
- Require approval for production changes.
- Implement change-management procedures.
- Secure third-party supplier accounts.
- Use HTTPS.
- Configure CSP and anti-clickjacking headers.

Result

The ZAP assessment successfully identified multiple web-application security weaknesses. The results demonstrate why strong administrator authentication, privileged-access management, logging and change control are important for public Wi-Fi portal infrastructure.

S.No .	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well-justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

